

Diseño y evaluación de una plataforma web segura de firma digital con Autoridad Certificadora simulada y prácticas DevSecOps

Marcos Escobar, Stefany Díaz, and Mateo Sosa

Universidad de las Fuerzas Armadas ESPE, Departamento de Ciencias de la Computación, Sangolquí, Ecuador
mdescobar6@espe.edu.ec, smdiaz5@espe.edu.ec, dmsosa3@espe.edu.ec

Resumen La firma electrónica sostiene trámites públicos y privados, pero las herramientas de referencia en Ecuador operan como aplicaciones de escritorio que exigen instalación local y concentran la verificación en el equipo del usuario. Este artículo presenta el diseño, la construcción y la evaluación de una plataforma web de firma digital y validación criptográfica que traslada ese ciclo completo al navegador. La solución se implementó como tres servicios containerizados, con un núcleo criptográfico que emite certificados X.509 firmados por una Autoridad Certificadora simulada, firma documentos PDF con RSA-PSS sobre SHA-256, cifra archivos con un esquema híbrido AES-256-GCM más RSA-OAEP y expone un portal público de verificación sin autenticación. El control de acceso se organizó en tres capas complementarias: verificación de token en el borde, matriz RBAC con alcance de propiedad en la aplicación y seguridad a nivel de fila en la base de datos. Todo el ciclo de vida se sometió a una canalización DevSecOps con siete puertas bloqueantes. La evaluación combinó cobertura de pruebas, auditoría de calidad de código, verificación de controles ofensivos y medición de latencia con treinta repeticiones por operación. La suite automatizada alcanzó 96,9% de cobertura sobre el núcleo criptográfico, los nueve controles de seguridad comprobados resultaron efectivos y la firma de un PDF de 5 MB se completó en 166 ms de media ($p99 = 183$ ms), un orden de magnitud por debajo del umbral de 2 s exigido. El análisis también identificó una limitación del limitador de peticiones que agrega a todos los clientes en una sola cuota.

Palabras clave Firma digital · Infraestructura de clave pública · X.509 · RSA-PSS · Cifrado híbrido · RBAC · Seguridad a nivel de fila · Zero Trust · DevSecOps

1 Introducción

La firma electrónica constituye un pilar operativo de la administración pública y privada. En Ecuador, la Ley de Comercio Electrónico, Firmas Electrónicas y Mensajes de Datos otorgó validez jurídica a los mensajes de datos firmados

y abrió el uso de certificados emitidos por entidades acreditadas [5]. Un marco equivalente rige en la Unión Europea a través del reglamento eIDAS, que clasifica las firmas según su nivel de garantía y define los servicios de confianza asociados [9]. En ambos casos, la confianza descansa sobre una infraestructura de clave pública cuyo funcionamiento depende de la emisión, la validación y la revocación correcta de certificados X.509 [6].

La herramienta de referencia en el contexto ecuatoriano, FIRMAEC, se distribuye históricamente como una aplicación de escritorio construida sobre Java [13]. Ese modelo impone una instalación local, ata al usuario a un equipo concreto y mantiene la verificación dentro de la propia aplicación. En consecuencia, un tercero que recibe un documento firmado carece de un mecanismo inmediato para comprobar su validez sin instalar el mismo programa. La fricción resultante afecta sobre todo a quien verifica, no a quien firma, y reduce el valor práctico de la evidencia criptográfica que el documento ya contiene.

El problema abordado se formuló de la siguiente manera: cómo diseñar y construir una plataforma de firma y validación criptográfica que resulte segura por diseño, accesible desde la web y verificable de extremo a extremo, sin renunciar al rigor de los algoritmos ni a la trazabilidad de las decisiones de ingeniería. La pregunta se descompuso en tres ejes: qué arquitectura sostiene un núcleo criptográfico expuesto a Internet, qué modelo de control de acceso contiene un fallo de una sola capa, y qué coste de latencia impone la criptografía asimétrica sobre operaciones interactivas.

Para responder esa pregunta se construyó SelloDigital, una plataforma web compuesta por una interfaz Nuxt 3, una pasarela de API en NestJS y un servicio criptográfico en Python con FastAPI, respaldados por PostgreSQL con políticas de seguridad a nivel de fila. El sistema cubre el ciclo completo: registro y sesión con token, emisión de certificados firmados por una Autoridad Certificadora simulada, firma de documentos PDF con sello visual opcional, cifrado híbrido de archivos, auditoría estructurada y un portal público donde cualquier persona valida un documento sin cuenta previa. El desarrollo se condujo bajo prácticas DevSecOps, con análisis estático, escaneo de dependencias y de contenedores como puertas bloqueantes de integración continua.

La contribución de este trabajo es cuádruple. Primero, se documenta una arquitectura de referencia que separa el núcleo criptográfico del punto de entrada público y aplica verificación explícita en cada salto, alineada con los principios de confianza cero [24]. Segundo, se describe un modelo de autorización en tres capas que combina RBAC con alcance de propiedad y seguridad a nivel de fila sobre una identidad propia basada en tokens JWT. Tercero, se aporta evidencia empírica sobre el coste de las operaciones criptográficas en un despliegue containerizado real, con separación entre el coste del algoritmo y el coste de la infraestructura. Cuarto, se reporta el resultado de una auditoría de calidad interna y de una batería de controles ofensivos, junto con las limitaciones que persistieron tras la remediación.

El resto del artículo se organiza como sigue. La sección 2 revisa el trabajo relacionado. La sección 3 describe la metodología, la arquitectura, el diseño

criptográfico, el modelo de acceso y el protocolo de evaluación. La sección 4 presenta y discute los resultados. La sección 5 resume las conclusiones y el trabajo futuro.

2 Trabajo relacionado

2.1 Infraestructura de clave pública y validación de certificados

El perfil de certificados y listas de revocación definido en el RFC 5280 establece la semántica que debe cumplir cualquier validador: verificación de la cadena hasta un ancla de confianza, comprobación del periodo de validez y consulta del estado de revocación [6]. Las especificaciones PKCS #1 formalizan los esquemas RSA empleados en la práctica, entre ellos RSASSA-PSS para firma y RSAES-OAEP para cifrado [14]. El respaldo teórico de ambos esquemas proviene de los trabajos de Bellare y Rogaway, que demostraron reducciones de seguridad ajustadas para el relleno probabilístico de firma [4] y para el cifrado asimétrico óptimo [3]. Las recomendaciones de gestión de claves del NIST sitúan el tamaño mínimo de módulo RSA en 3072 bits para material que debe permanecer seguro más allá de 2030 [2].

Sobre esa base normativa se apoyan también los perfiles de firma avanzada. La norma ETSI EN 319 142-1 define PAdES, el perfil que incrusta la firma dentro del propio documento PDF y añade información de validación a largo plazo [8]. El sellado de tiempo confiable, especificado en el RFC 3161, completa ese modelo con una prueba de existencia temporal emitida por un tercero [1]. La plataforma descrita en este artículo no implementa esos perfiles completos, decisión que se discute como limitación en la sección 4.7.

2.2 Plataformas de firma y el referente funcional

Las soluciones nacionales de firma electrónica siguen dos modelos. El primero distribuye una aplicación cliente que accede al certificado desde un token criptográfico o un archivo protegido, como ocurre con FIRMAEC [13]. El segundo traslada la operación a un servicio en línea, donde el proveedor custodia el material sensible o actúa como intermediario. Cada modelo desplaza el riesgo hacia un lugar distinto. El cliente de escritorio conserva la clave privada bajo control del usuario, aunque a costa de instalación, actualizaciones y dependencia del dispositivo. El servicio en línea simplifica el acceso, pero concentra un objetivo de alto valor en el servidor.

El diseño adoptado en este trabajo buscó un punto intermedio explícito. La clave privada del usuario se genera en el servidor durante la emisión, se entrega una única vez y no se persiste en ningún momento posterior. El servidor conserva únicamente el certificado público y sus metadatos, mientras que la clave de la Autoridad Certificadora permanece cifrada en disco como simulación de un módulo de seguridad de hardware. Esta decisión preserva la propiedad del material criptográfico por parte del titular sin exigir instalación local, y a la vez reconoce que el envío de la clave en cada operación de firma constituye un compromiso que se discute más adelante.

2.3 Control de acceso en capas y confianza cero

El modelo de control de acceso basado en roles formalizado por Sandhu et al. estructura los permisos como una relación entre roles y operaciones, en lugar de asignaciones directas a usuarios [26]. Ese modelo resuelve la autorización funcional, pero no expresa por sí solo la pertenencia de un recurso a un titular concreto. La práctica habitual combina el permiso de rol con una comprobación de propiedad en la capa de aplicación, y añade una segunda barrera en el motor de datos. PostgreSQL ofrece esa barrera mediante políticas de seguridad a nivel de fila, que filtran los registros antes de devolverlos a la consulta [21].

La arquitectura de confianza cero descrita por el NIST sistematiza estos principios: ningún componente debe confiar en otro por su ubicación de red, cada petición debe verificarse de forma explícita y todo acceso debe otorgarse con el mínimo privilegio necesario [24]. La formulación original de esos principios se remonta al trabajo de Saltzer y Schroeder, que enunció el mínimo privilegio y la economía del mecanismo como criterios de diseño de sistemas protegidos [25]. La plataforma evaluada aplicó esos criterios de forma pragmática, con verificación de token en cada servicio y autenticación de las llamadas internas.

2.4 DevSecOps y aseguramiento de la calidad

La revisión multivocal de Myrbakken y Colomo-Palacios caracterizó DevSecOps como la extensión del ciclo DevOps con responsabilidades de seguridad distribuidas y automatizadas [15]. De acuerdo con Rahman y Williams, las organizaciones que adoptan estas prácticas se apoyan sobre todo en la automatización de comprobaciones y en el monitoreo continuo, más que en revisiones manuales al final del ciclo [23]. El catálogo OWASP Top 10 proporciona la taxonomía de riesgos más difundida para orientar esas comprobaciones [20], mientras que la guía de pruebas de seguridad web ofrece el procedimiento de verificación correspondiente [18] y el estándar ASVS define niveles de exigencia por tipo de control [19]. La calidad del producto resultante se interpretó según el modelo ISO/IEC 25010, en particular sus características de seguridad y mantenibilidad [11].

2.5 Brecha abordada

Los estándares citados describen qué debe cumplir un sistema de firma, y la literatura de seguridad describe cómo estructurar sus controles, pero la evidencia pública sobre la integración completa de ambos aspectos en una plataforma web verificable resulta escasa. En particular, la documentación disponible rara vez reporta a la vez el coste de las operaciones asimétricas en un despliegue containerizado, el resultado de una auditoría de calidad interna y la comprobación empírica de los controles de acceso frente a intentos de abuso. Este trabajo cubre esa brecha con un caso completo y medido, y expone tanto los controles efectivos como las limitaciones que sobrevivieron a la fase de remediación.

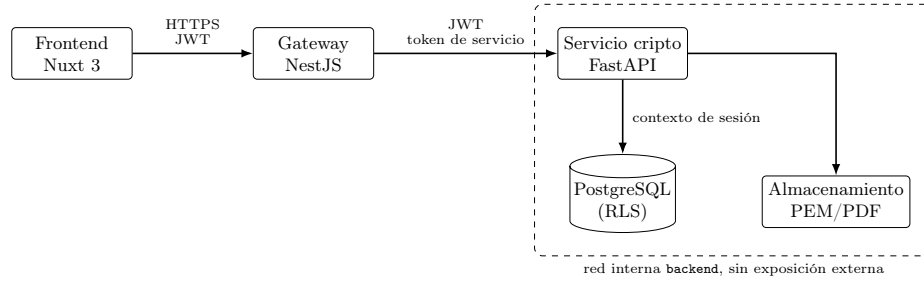


Figura 1. Componentes de la plataforma y camino de una petición autenticada. Solo la interfaz y la pasarela se exponen fuera de la red de contenedores.

3 Metodología

3.1 Diseño de la investigación

El estudio siguió un enfoque de ciencia del diseño, en el cual el artefacto construido constituye a la vez el resultado y el objeto de evaluación [10]. El desarrollo se organizó en diez incrementos sucesivos, desde la preparación del repositorio y la migración del prototipo hasta el despliegue en laboratorio y las pruebas ofensivas. Cada incremento cerró con commits atómicos y con la actualización de la documentación de requisitos, de modo que la trazabilidad entre objetivo, requisito, código y evidencia se mantuvo a lo largo del ciclo.

La evaluación se diseñó como una verificación multicriterio en lugar de una única medida de éxito. Se combinaron cuatro fuentes de evidencia: la suite de pruebas automatizadas con su cobertura, la auditoría de calidad de código con su plan de acciones correctivas, la batería de controles ofensivos ejecutada contra el despliegue, y la medición de latencia de las operaciones criptográficas. Esta estructura evita que un resultado favorable en una dimensión oculte una debilidad en otra, y permite atribuir cada afirmación a una evidencia reproducible.

3.2 Arquitectura del sistema

El sistema adoptó un estilo cliente-servidor con servicios containerizados y un único punto de entrada. La figura 1 presenta los componentes y el camino que recorre una petición. El navegador solicita a la interfaz Nuxt, que envía las llamadas de API a la pasarela NestJS con el token de acceso del usuario. La pasarela verifica ese token en el borde y reenvía la petición al servicio criptográfico junto con un token de servicio compartido. El servicio criptográfico vuelve a verificar el token del usuario, fija el contexto de identidad en la transacción de base de datos y ejecuta la operación.

La separación de responsabilidades respondió a dos motivos. Por un lado, aisló el núcleo criptográfico, que concentra el material sensible, detrás de un componente sin lógica de negocio. Por otro, permitió que la pasarela operase como proxy transparente sin analizador de cuerpo, de modo que los envíos multiparte y

las descargas binarias atraviesan el borde sin modificación. La red de contenedores se segmentó en dos: una red externa que publica únicamente la interfaz y la pasarela, y una red interna que aloja el servicio criptográfico y la base de datos sin ruta hacia el exterior. El volumen de código resultante fue de 3491 líneas en el núcleo Python, 338 en la pasarela y 4735 en la interfaz, con 28 rutas de API expuestas.

3.3 Diseño criptográfico

La Autoridad Certificadora simulada se genera una sola vez durante el primer arranque. Su par de claves RSA de 4096 bits produce un certificado raíz autofirmado con validez de 3650 días, con la restricción básica de autoridad y los usos de clave limitados a la firma de certificados y de listas de revocación. La clave privada de esa autoridad se almacena cifrada con una contraseña de despliegue y con permisos restringidos, lo que simula el resguardo que ofrecería un módulo de hardware. Los certificados de usuario se emiten con clave RSA de 3072 bits, validez de 365 días y usos de clave de firma digital y no repudio, y quedan firmados por la autoridad raíz en lugar de autofirmarse.

El proceso de firma de documentos se apoya en un digest previo. Dado un documento D , el sistema calcula primero su resumen con SHA-256 según la ecuación 1, conforme al estándar de funciones resumen [16]:

$$h = \text{SHA-256}(D) \quad (1)$$

A continuación, la firma se calcula sobre ese resumen con el esquema probabilístico RSASSA-PSS, con función de máscara MGF1 sobre SHA-256 y longitud de sal máxima, de acuerdo con la ecuación 2 [14,17]:

$$\sigma = \text{PSS-Sign}(sk_u, h) \quad (2)$$

El artefacto resultante se guarda como un archivo independiente con extensión `.sig`, sin alteración del documento original, salvo que el usuario solicite el sello visual. En ese caso, el sistema incrusta primero una marca con un código QR que enlaza al portal de verificación, y firma después el resumen del documento ya sellado, de modo que la evidencia criptográfica cubre exactamente el archivo que el destinatario recibe.

La verificación pública combina tres comprobaciones independientes. El veredicto que devuelve el portal se define según la ecuación 3, donde i indica que el resumen recalculado coincide con el registrado, s indica que la firma valida contra la clave pública del certificado y c indica que el certificado supera la validación de cadena, vigencia y estado de revocación:

$$v = i \wedge s \wedge c \quad (3)$$

Esta descomposición resulta relevante en la práctica, porque un documento puede conservar una firma matemáticamente válida y aun así recibir un veredicto negativo cuando el certificado del firmante fue revocado. El portal comunica

Tabla 1. Parámetros criptográficos por operación.

Operación	Parámetros	Referencia
Contraseñas	bcrypt, factor de coste 12	[22]
Sesión	JWT HS256, acceso 1 h, refresco 24 h, lista de revocación por <code>jti</code>	[12]
CA raíz	RSA-4096, SHA-256, 3650 días	[6,2]
Certificado de usuario	RSA-3072, SHA-256, 365 días	[6,2]
Integridad	SHA-256	[16]
Firma	RSASSA-PSS, MGF1-SHA-256, sal máxima	[14,4]
Cifrado de archivos	AES-256-GCM y RSA-OAEP-SHA-256	[7,3]

los tres factores por separado, en lugar de reducirlos a una etiqueta binaria sin explicación.

El cifrado de archivos empleó un esquema híbrido. El contenido se cifra con AES-256 en modo GCM, que aporta confidencialidad y autenticación del mensaje en una sola operación [7], mientras que la clave simétrica se protege con RSA-OAEP bajo la clave pública del certificado destinatario. El sobre resultante se describe en la ecuación 4, donde k es la clave de sesión y n el nonce:

$$E = (\text{AES-GCM}_k(M), \text{OAEP-Enc}(pk_u, k), n) \quad (4)$$

Esta combinación evita el coste de cifrar el contenido completo con RSA y restringe la operación asimétrica a los 32 bytes de la clave de sesión. La tabla 1 resume los parámetros criptográficos adoptados en cada operación, junto con la referencia normativa que los respalda.

3.4 Modelo de control de acceso en profundidad

El control de acceso se estructuró en tres capas complementarias, de forma que el fallo de una quede contenido por la siguiente. La primera capa reside en la pasarela, que verifica la firma del token, comprueba que el tipo declarado corresponda a un token de acceso y rechaza cualquier ruta no pública sin credencial válida. La segunda capa reside en el servicio criptográfico, que repite la verificación del token y consulta la matriz de permisos antes de ejecutar cualquier acción. La tercera capa reside en la base de datos, que filtra las filas según el usuario y el rol fijados para la transacción en curso.

La matriz de permisos adoptó la convención `acción:recurso:alcance`, donde el alcance distingue entre recursos propios y recursos de cualquier titular. La decisión de autorización para un permiso con alcance responde a la ecuación 5, en la cual u es el usuario autenticado, r el recurso solicitado y a la acción pretendida:

Tabla 2. Resumen de la matriz RBAC por rol. El símbolo • indica permiso sobre recursos propios y ■ permiso sobre recursos de cualquier titular.

Grupo de permisos	público	firmante	admin
Registro de usuario y descarga de la CA raíz	■	■	■
Verificación pública de documentos y cálculo de resumen	■	■	■
Gestión del propio usuario	—	•	■
Emisión, consulta y revocación de certificados	—	•	■
Carga, firma, descarga y borrado de documentos	—	•	■
Cifrado y descifrado de archivos	—	•	•
Listado de usuarios y auditoría global	—	—	■
Configuración de la Autoridad Certificadora	—	—	■

$$\text{permitir}(u, a, r) = (\text{titular}(r) = u \wedge a:\text{own} \in P_{\text{rol}(u)}) \vee (a:\text{any} \in P_{\text{rol}(u)}) \quad (5)$$

Esta función se implementó en un único módulo que actúa como fuente de verdad de los permisos, con lo que se evitó la dispersión de comprobaciones de rol a lo largo del código. La tabla 2 resume la asignación resultante para los tres roles del sistema.

La tercera capa se resolvió con políticas de seguridad a nivel de fila. Tras la verificación del token, la aplicación fija el identificador y el rol del usuario como variables locales de la transacción, y las políticas de las tablas de certificados, documentos, auditoría y revocaciones consultan esas variables. El uso de variables locales resulta necesario con agrupación de conexiones, porque el valor se descarta al terminar la transacción y no se filtra hacia otra petición que reutilice la misma conexión. Las tablas sensibles se declararon con la modalidad forzada, y la aplicación se conecta con un rol de base de datos que carece del privilegio de omisión de políticas.

La confianza entre servicios se resolvió con un token compartido que la pasarela añade a cada llamada interna y que el servicio criptográfico compara en tiempo constante. Ningún componente concede acceso por pertenecer a la misma red, lo que materializa el principio de verificación explícita [24]. La figura 2 sintetiza el flujo de firma y de verificación con las comprobaciones que se ejecutan en cada etapa.

3.5 Canalización DevSecOps

La integración continua se configuró con siete trabajos bloqueantes que se ejecutan en cada envío y en cada solicitud de incorporación. La tabla 3 detalla

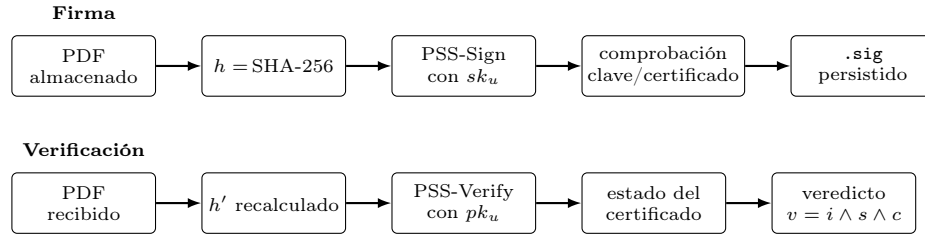


Figura 2. Flujo de firma y de verificación pública. La correspondencia entre la clave privada y el certificado se comprueba antes de escribir cualquier archivo.

Tabla 3. Puertas bloqueantes de la canalización de integración continua.

Puerta	Herramienta	Criterio de bloqueo
Estilo	ruff	Cualquier infracción de las reglas activas
Pruebas	pytest	Fallo de un caso o cobertura inferior al 85 %
Análisis estático	Bandit	Cualquier hallazgo no justificado
Dependencias Python	pip-audit	Vulnerabilidad conocida en el manifiesto
Dependencias Node	npm audit	Severidad alta o superior
Compilación y pruebas del borde	tsc , Vitest, Nuxt	Error de compilación o de prueba
Imagen de contenedor	Trivy	Vulnerabilidad alta o crítica con corrección disponible

la herramienta y el criterio de bloqueo de cada puerta. El conjunto cubre estilo, corrección funcional, análisis estático de seguridad, composición de dependencias y superficie de la imagen de contenedor, con lo que traslada la verificación al inicio del ciclo en lugar de concentrarla en una revisión final [15].

El endurecimiento del despliegue complementó esas puertas. La imagen del servicio criptográfico se construye sobre una base mínima, ejecuta con un usuario sin privilegios ni intérprete de comandos, y restringe la escritura al directorio de almacenamiento. Los secretos permanecen fuera del repositorio y se inyectan como variables de entorno, con validación de longitud mínima en el arranque de cada servicio, de modo que una configuración débil impide el inicio en lugar de degradar la seguridad de forma silenciosa.

3.6 Protocolo de evaluación

La evaluación se ejecutó sobre un equipo con procesador AMD Ryzen 5 5600X de seis núcleos, 16 GB de memoria y núcleo Linux 7.1.4, con Docker 29.6.2 y Python 3.12. Se emplearon dos escenarios de medición. El escenario E1 ejecutó el

servicio criptográfico en proceso, con un cliente de pruebas y una base de datos SQLite, con el propósito de aislar el coste del algoritmo. El escenario E2 midió el sistema completo desde el exterior, contra la pasarela del despliegue con Docker Compose, con PostgreSQL 16 y las políticas de seguridad a nivel de fila activas.

Cada operación se repitió treinta veces, con una ejecución previa de calentamiento que se descartó. La única excepción fue el inicio de sesión en el escenario E2, limitado a quince repeticiones porque el limitador de peticiones admite veinte solicitudes por minuto sobre las rutas de autenticación. Para cada operación se registraron la media, la desviación estándar y los percentiles 50, 95 y 99. Las mediciones de firma y de verificación se repitieron con documentos de 100 KB, 1 MB y 5 MB, con el fin de observar la sensibilidad al tamaño del archivo frente al coste fijo de las operaciones asimétricas.

La verificación de los controles de seguridad se realizó con un guión automatizado derivado de la guía de pruebas OWASP [18], ejecutado contra el despliegue en funcionamiento. Las pruebas cubrieron la segmentación de red, las cabeceras de respuesta, la manipulación de tokens, la escalada vertical de privilegios, el acceso a recursos ajenos, el recorrido de rutas y el limitador de peticiones. La calidad interna se evaluó con una auditoría manual asistida sobre la capa de rutas, servicios y repositorios del núcleo Python, guiada por un listado de comprobación de principios SOLID, código limpio y seguridad, con clasificación de hallazgos en no conformidades mayores, menores y oportunidades de mejora.

4 Resultados y discusión

4.1 Cobertura funcional y verificación de requisitos

La plataforma implementó los diez objetivos específicos planteados al inicio del proyecto. La tabla 4 presenta la correspondencia entre cada objetivo y la evidencia que sustenta su cumplimiento. La verificación no se apoyó en la inspección visual de la interfaz, sino en pruebas automatizadas que ejercitan el contrato HTTP y en la comprobación de los artefactos generados, como el archivo de firma, el certificado emitido y el registro de auditoría.

Adicionalmente, la plataforma incorporó dos elementos ausentes en el referente funcional. El primero fue el portal público de verificación, que resuelve el veredicto de un documento sin exigir cuenta ni instalación al destinatario. El segundo fue el sello visual con código QR incrustado en el propio PDF, que enlaza a ese portal y traslada la evidencia al documento que circula. Ambos elementos operan sobre una infraestructura simulada y, por tanto, no otorgan validez legal, extremo que se declara de forma explícita en la interfaz.

4.2 Calidad interna y remediación de la auditoría

La auditoría de calidad no detectó no conformidades mayores de seguridad ni defectos funcionales. Los seis hallazgos registrados correspondieron a mantenibilidad y se concentraron en la capa de rutas, con controladores que

Tabla 4. Trazabilidad entre objetivos específicos y evidencia de verificación.

Objetivo	Evidencia
Autenticación y sesión	7 pruebas de autenticación, rechazo de token manipulado, lista de revocación por identificador
CRUD de usuarios, certificados y documentos	28 rutas de API, 20 pruebas sobre los tres recursos
CA simulada y certificados X.509	5 pruebas de emisión, cadena, vigencia y revocación con CRL pública
Firma y verificación de documentos	8 pruebas de firma, detección de alteración y veredicto público
Cifrado híbrido de archivos	4 pruebas de resumen, cifrado, descifrado y clave incorrecta
Integridad con SHA-256	Resumen registrado en la carga y recalculado en cada verificación
Auditoría de accesos y eventos	Registro estructurado en base de datos con degradación ante fallo
Canalización DevSecOps	7 puertas bloqueantes en integración continua
Despliegue y pruebas ofensivas	9 controles verificados sobre el despliegue
Análisis estadístico de pruebas	14 operaciones medidas con 30 repeticiones

asumían orquestación de negocio y con duplicación del mapeo entre excepciones y códigos HTTP. La tabla 5 resume cada hallazgo y la acción correctiva aplicada. El ciclo se cerró en dos incrementos de mantenimiento, con verificación de eficacia mediante la suite de regresión y sin cambios en el contrato HTTP público.

La reproducción de las comprobaciones sobre la versión liberada confirmó el estado del producto. La suite del núcleo criptográfico ejecutó 50 pruebas sin fallos, con una cobertura de 96,9 % sobre 1397 sentencias y 43 sentencias sin cubrir, resultado que supera la puerta del 85 % configurada en la canalización. Las pruebas del borde ejecutaron 10 casos sobre el guardián de tokens y la lista de rutas públicas. El análisis estático de seguridad recorrió 2672 líneas sin hallazgos, con una única supresión justificada y documentada. El análisis de estilo resultó limpio con la versión de herramienta empleada en la auditoría.

Las sentencias no cubiertas se concentraron en rutas de error de baja frecuencia, como la ausencia de un archivo en disco durante la verificación o el fallo de escritura de permisos sobre la clave de la autoridad. Esa distribución resulta coherente con el criterio de diseño de la suite, orientada a los flujos críticos de seguridad y a los caminos de denegación, más que a la búsqueda de una cobertura total. La ausencia de no conformidades mayores, junto con una cobertura superior al umbral, sitúa el producto en un nivel de mantenibilidad aceptable según el modelo de calidad adoptado [11].

Tabla 5. Hallazgos de la auditoría de código y acción correctiva.

ID	Hallazgo	Severidad	Acción
NC-01	Orquestación de la firma dentro del controlador	Menor	Extracción de un servicio de firma
NC-02	Duplicación del mapeo excepción a HTTP	Menor	Excepciones de dominio y manejadores centrales
NC-03	Construcción repetida de servicios	Menor	Constructor único compartido
NC-04	Literales de estado y rol dispersos	Mejora	Módulo de constantes con nombre
NC-05	Fuga de mensajes internos al cliente	Menor	Mensaje genérico y detalle solo en auditoría
NC-06	Suite dependiente del entorno local	Menor	Aislamiento del entorno en la configuración de pruebas

4.3 Efectividad de los controles de seguridad

La batería de controles ofensivos se ejecutó contra el despliegue completo y verificó nueve controles sin fallos. La tabla 6 detalla cada prueba, el riesgo asociado del catálogo OWASP y el resultado observado. Los casos más relevantes fueron la denegación del acceso a un certificado ajeno, que confirma la comprobación de propiedad, y el rechazo de un token con algoritmo declarado como nulo, que confirma la validación estricta de la firma en el borde.

La gestión de vulnerabilidades registró siete hallazgos durante el desarrollo, tres de severidad alta y cuatro de severidad media, todos resueltos antes del cierre. Entre los de severidad alta figuraron un depurador remoto habilitado en el prototipo inicial, un secreto de firma débil sin longitud mínima y un recorrido de rutas en la descarga de documentos. Su corrección siguió el mismo patrón en los tres casos: eliminación de la causa, incorporación de una prueba que reproduce el abuso y adición de una puerta automática que impide la reintroducción. Junto a ellos se documentaron seis riesgos aceptados de forma explícita, con su justificación y su plan de revisión.

4.4 Rendimiento de las operaciones criptográficas

La tabla 7 presenta la latencia medida en los dos escenarios descritos en la sección 3.6. La figura 3 compara la media y el percentil 95 del escenario extremo a extremo para las operaciones más representativas. Los resultados muestran tres patrones consistentes.

El primer patrón es la insensibilidad de la firma al tamaño del documento. La latencia media pasó de 166,1 ms con un archivo de 1 MB a 166,4 ms con un archivo de 5 MB, diferencia inferior a la desviación estándar de la propia

Tabla 6. Controles de seguridad verificados sobre el despliegue en funcionamiento.

ID	Control	Riesgo	Resultado
P-02	Aislamiento del servicio criptográfico	A05	No alcanzable
P-10	Cabecera contra inferencia de tipo de contenido	A05	Presente
P-10	Cabecera contra inclusión en marcos	A05	Presente
P-06	Token con algoritmo nulo	A02	Rechazado (401)
P-05	Escalada vertical a listado de usuarios	A01	Denegado (403)
P-05	Escalada vertical a auditoría global	A01	Denegado (403)
P-04	Acceso a certificado de otro titular	A01	Denegado (403)
P-08	Recorrido de rutas en documentos	A01	Bloqueado (404)
P-03	Límite de peticiones en autenticación	A07	Activo (429)

serie. El cálculo del resumen sobre 1 MB costó 5,7 ms, de modo que el tiempo dominante no proviene del recorrido del archivo sino de la carga y la validación de la clave privada en formato PEM junto con la operación RSA. Ese coste fijo es consecuencia directa de la decisión de no persistir claves de usuario, que obliga a deserializar el material en cada petición.

El segundo patrón es la asimetría entre operaciones de clave privada y de clave pública. La verificación pública de un documento de 1 MB requirió 8,3 ms frente a los 166,1 ms de la firma, y el cifrado híbrido requirió 21,9 ms frente a los 130,9 ms del descifrado. Esta relación, cercana a un factor de veinte y de seis respectivamente, favorece el caso de uso previsto: la verificación es la operación más frecuente en un portal público y resulta también la más económica, lo que reduce el riesgo de agotamiento de recursos ante consultas masivas.

El tercer patrón es el coste de la infraestructura. La diferencia entre ambos escenarios se mantuvo por debajo de 80 ms en todas las operaciones y no superó los 6 ms en la verificación pública ni en el cálculo del resumen. Ese sobre coste incluye el proxy de la pasarela, el recorrido de la red de contenedores, PostgreSQL con las políticas de fila activas y el registro de auditoría.

En el inicio de sesión la diferencia resultó nula dentro del margen de dispersión, resultado esperable porque el tiempo lo domina el cálculo de bcrypt y no la infraestructura. La comprobación de salud de la pasarela, que no atraviesa el núcleo criptográfico, respondió en 0,6 ms de media, lo que confirma que el sobre coste observado corresponde al trabajo real de cada operación y no a una ineficiencia del borde.

En conjunto, los requisitos de rendimiento establecidos durante el análisis se cumplieron con margen amplio. El umbral de dos segundos para la firma y la

Tabla 7. Latencia por operación en milisegundos. E1 corresponde al servicio criptográfico en proceso y E2 al sistema completo a través de la pasarela ($n = 30$; $n = 15$ en el inicio de sesión de E2).

Operación	E1		E2		
	media	p95	media	p95	p99
Salud de la pasarela	—	—	0,6	0,7	0,7
Registro de usuario	211,3	218,5	226,4	258,5	275,1
Inicio de sesión	212,1	216,1	202,7	216,5	216,8
Emisión de certificado	346,9	493,1	415,0	558,2	949,2
Firma de PDF (100 KB)	107,2	110,0	170,0	229,6	233,5
Firma de PDF (1 MB)	108,8	111,0	166,1	166,9	166,9
Firma de PDF (5 MB)	117,3	132,8	166,4	167,0	183,1
Firma con sello visual (100 KB)	176,3	218,9	255,6	337,9	509,0
Verificación pública (100 KB)	4,5	4,9	8,6	8,7	17,0
Verificación pública (1 MB)	5,7	6,2	8,3	8,7	8,9
Verificación pública (5 MB)	11,3	12,2	17,2	17,3	33,5
Resumen SHA-256 (1 MB)	4,0	4,4	5,7	6,3	6,4
Cifrado híbrido (1 MB)	8,0	8,7	21,9	66,7	108,5
Descifrado híbrido (1 MB)	113,9	114,7	130,9	175,2	417,9

verificación de documentos menores a 5 MB se satisfizo incluso en el percentil 99 observado, con 233,5 ms para la firma de 100 KB y 183,1 ms para la de 5 MB. El umbral de un segundo para el inicio de sesión también se cumplió, con 216,8 ms en el percentil 99. Conviene señalar que ese tiempo lo domina el factor de coste de bcrypt, elegido de forma deliberada para encarecer los ataques de fuerza bruta contra contraseñas almacenadas [22]. La latencia de autenticación constituye, en este caso, un parámetro de seguridad y no una ineficiencia.

4.5 Comparación con el referente funcional

La tabla 8 contrasta la plataforma con el referente de escritorio en las dimensiones que motivaron el trabajo. Las diferencias corresponden a experiencia de uso y a arquitectura, y no implican equivalencia legal, dado que la Autoridad Certificadora empleada es simulada y carece de acreditación.

4.6 Discusión

Los resultados sostienen tres afirmaciones. La primera es que la defensa en profundidad resultó verificable y no solo declarativa: los intentos de escalada vertical y de acceso a recursos ajenos recibieron denegación en la capa de aplicación, mientras que las políticas de fila permanecieron como red de seguridad ante un eventual descuido de esa capa. La segunda es que el coste de la criptografía asimétrica resulta compatible con una experiencia interactiva, siempre que

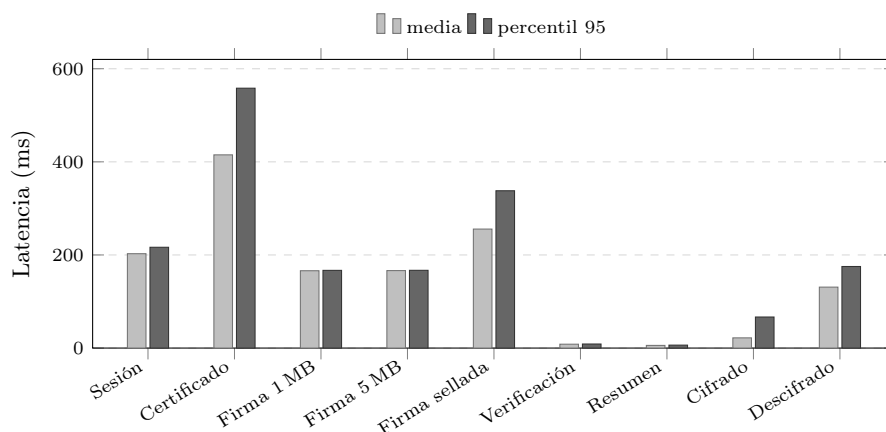


Figura 3. Latencia media y percentil 95 en el escenario extremo a extremo. La verificación pública y el resumen corresponden a documentos de 1 MB.

la operación frecuente sea la verificación y no la firma. La tercera es que la automatización temprana de las comprobaciones de seguridad detectó defectos reales durante el desarrollo, entre ellos un recorrido de rutas y un secreto débil, en lugar de dejarlos para una revisión final.

La evaluación también reveló una debilidad que la documentación previa no registraba. El limitador de peticiones del servicio criptográfico agrupa las solicitudes por la dirección de origen de la conexión, que en este despliegue corresponde siempre a la pasarela. Una comprobación empírica confirmó el efecto: tras agotar la cuota desde un cliente, una petición emitida desde una dirección distinta recibió respuesta 429 originada en el servicio criptográfico. En consecuencia, la cuota de autenticación se comporta como un límite global y un solo cliente puede impedir el inicio de sesión del resto durante la ventana activa. La corrección pasa por la lectura de la cabecera de reenvío que la pasarela ya propaga, o por el traslado del límite a un almacén compartido.

Este hallazgo ilustra un riesgo común en arquitecturas con pasarela: un control correcto en el borde puede degradarse al replicarse en un servicio interno que observa una única dirección de origen. La duplicación del control obedecía al principio de verificación explícita, y en ese sentido la decisión de diseño fue acertada, pero la implementación interna necesitaba distinguir el cliente real. El caso confirma la utilidad de las pruebas ofensivas sobre el despliegue completo, ya que ninguna prueba unitaria del limitador habría expuesto la agregación.

4.7 Limitaciones y amenazas a la validez

El alcance del trabajo impone varias limitaciones. La Autoridad Certificadora es simulada y carece de acreditación, por lo que ningún documento firmado posee validez jurídica. La firma se materializa como un artefacto independiente y no

Tabla 8. Contraste con el referente funcional de escritorio.

Aspecto	Referente de escritorio	Plataforma propuesta
Acceso	Instalación local por equipo	Navegador, sin instalación
Verificación	Dentro de la aplicación	Portal público por enlace o QR
Origen del certificado	Autoridad acreditada externa	Autoridad simulada con emisión en línea
Revocación	Gestionada por la autoridad emisora	Registro propio con lista consultable
Trazabilidad	Visibilidad limitada	Panel de auditoría por usuario
Validez jurídica	Sí	No, alcance académico

como una firma incrustada conforme a los perfiles PAdES [8], ni incorpora sellado de tiempo de un tercero [1], ausencias que impiden la validación a largo plazo. Además, la clave privada del usuario viaja en el cuerpo de la petición durante la firma y el descifrado, decisión que se documentó como riesgo aceptado bajo el supuesto de transporte cifrado y que tendría solución mediante operaciones criptográficas en el navegador.

Las mediciones presentan igualmente amenazas a la validez. Se ejecutaron sobre un único equipo, sin concurrencia y sin latencia de red externa, por lo que describen el coste intrínseco de cada operación y no el comportamiento bajo carga sostenida. El escenario E1 empleó SQLite en lugar de PostgreSQL, de modo que sus cifras no reflejan el coste de las políticas de fila, aunque la comparación con E2 permite acotar esa diferencia. La suite de pruebas comparte esa restricción: al ejecutarse sobre SQLite, ejerce el control de acceso de la capa de aplicación pero no las políticas de la base de datos, cuya verificación quedó cubierta únicamente por las pruebas ejecutadas contra el despliegue.

Por último, la batería ofensiva cubrió los controles automatizables y no sustituye una evaluación manual completa. Quedaron pendientes el escaneo web guiado, la exploración de inyección con herramientas especializadas y el análisis de la configuración de transporte, previstos sobre el laboratorio virtualizado con una estación atacante dedicada. La cobertura de riesgos declarada se limita, por tanto, a los controles efectivamente verificados en la tabla 6.

5 Conclusiones y trabajo futuro

Este artículo presentó el diseño, la construcción y la evaluación de una plataforma web de firma digital con Autoridad Certificadora simulada, control de acceso en tres capas y prácticas DevSecOps aplicadas a lo largo del ciclo de vida. El sistema cubrió la emisión de certificados X.509, la firma de documentos PDF con

RSA-PSS sobre SHA-256, el cifrado híbrido de archivos y la verificación pública sin autenticación, con auditoría estructurada de todos los eventos relevantes.

La evaluación multicriterio arrojó resultados consistentes. La suite automatizada alcanzó 96,9% de cobertura sobre el núcleo criptográfico con 50 pruebas sin fallos, la auditoría de calidad cerró sus seis hallazgos sin no conformidades mayores, los nueve controles de seguridad comprobados resultaron efectivos sobre el despliegue y las operaciones criptográficas se mantuvieron por debajo de los umbrales exigidos, con 166 ms de media para la firma de un documento de 5 MB y 17 ms para su verificación pública. La medición también mostró que el coste de la firma depende de la carga de la clave privada y no del tamaño del documento, dato relevante para el dimensionamiento de sistemas similares.

El estudio identificó además una limitación del limitador de peticiones, que agrega a todos los clientes en una cuota única al observar solo la dirección de la pasarela. Ese hallazgo, obtenido únicamente gracias a la prueba sobre el despliegue completo, refuerza el argumento de que la verificación de controles de seguridad debe ejecutarse sobre el sistema integrado y no solo sobre sus componentes aislados.

El trabajo futuro se orienta en cuatro direcciones. La primera consiste en trasladar las operaciones con clave privada al navegador mediante interfaces criptográficas web, con lo que la clave dejaría de viajar en la petición. La segunda consiste en adoptar un perfil de firma incrustada conforme a PAdES y añadir sellado de tiempo, con el fin de habilitar la validación a largo plazo. La tercera consiste en sustituir la firma simétrica de los tokens por un esquema asimétrico y en implantar autenticación mutua entre contenedores. La cuarta consiste en ampliar la evaluación con pruebas de carga concurrente y con la batería ofensiva manual pendiente, de modo que las conclusiones sobre capacidad y resistencia se apoyen en evidencia equivalente a la ya reportada sobre corrección y latencia.

Disponibilidad de datos y código. El código fuente, la documentación de requisitos, los informes de auditoría y los guiones de medición se conservan en el repositorio del proyecto. Los datos de latencia reportados corresponden a la ejecución descrita en la sección 3.6 y pueden reproducirse con los guiones incluidos.

Declaración sobre el uso de IA generativa. Se emplearon herramientas de IA generativa como apoyo en la redacción y en la revisión de estilo. El autor revisó y asume la responsabilidad completa sobre el contenido técnico, los análisis y las conclusiones.

Referencias

1. Adams, C., Cain, P., Pinkas, D., Zuccherato, R.: Internet X.509 public key infrastructure time-stamp protocol (TSP). Tech. Rep. RFC 3161, Internet Engineering Task Force (2001). <https://doi.org/10.17487/RFC3161>

2. Barker, E.: Recommendation for key management: Part 1 – general. Tech. Rep. NIST Special Publication 800-57 Part 1 Rev. 5, National Institute of Standards and Technology (2020). <https://doi.org/10.6028/NIST.SP.800-57pt1r5>
3. Bellare, M., Rogaway, P.: Optimal asymmetric encryption. In: Advances in Cryptology – EUROCRYPT '94. LNCS, vol. 950, pp. 92–111. Springer (1995). <https://doi.org/10.1007/BFb0053428>
4. Bellare, M., Rogaway, P.: The exact security of digital signatures: How to sign with RSA and Rabin. In: Advances in Cryptology – EUROCRYPT '96. LNCS, vol. 1070, pp. 399–416. Springer (1996). https://doi.org/10.1007/3-540-68339-9_34
5. Congreso Nacional del Ecuador: Ley de comercio electrónico, firmas electrónicas y mensajes de datos. Registro Oficial Suplemento 557 (2002)
6. Cooper, D., Santesson, S., Farrell, S., Boeyen, S., Housley, R., Polk, W.: Internet X.509 public key infrastructure certificate and certificate revocation list (CRL) profile. Tech. Rep. RFC 5280, Internet Engineering Task Force (2008). <https://doi.org/10.17487/RFC5280>
7. Dworkin, M.: Recommendation for block cipher modes of operation: Galois/Counter mode (GCM) and GMAC. Tech. Rep. NIST Special Publication 800-38D, National Institute of Standards and Technology (2007). <https://doi.org/10.6028/NIST.SP.800-38D>
8. ETSI: EN 319 142-1: Electronic signatures and infrastructures (ESI); PAdES digital signatures; part 1: Building blocks and PAdES baseline signatures. European Telecommunications Standards Institute (2016)
9. European Parliament and Council: Regulation (EU) no 910/2014 on electronic identification and trust services for electronic transactions in the internal market (eIDAS). Official Journal of the European Union, L 257/73 (2014)
10. Hevner, A., March, S., Park, J., Ram, S.: Design science in information systems research. *MIS Quarterly* **28**(1), 75–105 (2004). <https://doi.org/10.2307/25148625>
11. International Organization for Standardization: ISO/IEC 25010:2011 systems and software engineering – systems and software quality requirements and evaluation (SQuaRE) – system and software quality models. Standard (2011)
12. Jones, M., Bradley, J., Sakimura, N.: JSON web token (JWT). Tech. Rep. RFC 7519, Internet Engineering Task Force (2015). <https://doi.org/10.17487/RFC7519>
13. Ministerio de Telecomunicaciones y de la Sociedad de la Información: FIRMAEC: Aplicación de firma electrónica del ecuador. <https://www.firmadigital.gob.ec> (2024)
14. Moriarty, K., Kaliski, B., Jonsson, J., Rusch, A.: PKCS #1: RSA cryptography specifications version 2.2. Tech. Rep. RFC 8017, Internet Engineering Task Force (2016). <https://doi.org/10.17487/RFC8017>
15. Myrbakken, H., Colomo-Palacios, R.: DevSecOps: A multivocal literature review. In: Software Process Improvement and Capability Determination (SPICE 2017). CCIS, vol. 770, pp. 17–29. Springer (2017). https://doi.org/10.1007/978-3-319-67383-7_2
16. National Institute of Standards and Technology: Secure hash standard (SHS). Tech. Rep. FIPS PUB 180-4, National Institute of Standards and Technology (2015). <https://doi.org/10.6028/NIST.FIPS.180-4>
17. National Institute of Standards and Technology: Digital signature standard (DSS). Tech. Rep. FIPS PUB 186-5, National Institute of Standards and Technology (2023). <https://doi.org/10.6028/NIST.FIPS.186-5>
18. OWASP Foundation: OWASP web security testing guide, version 4.2. <https://owasp.org/www-project-web-security-testing-guide/> (2020)

19. OWASP Foundation: OWASP application security verification standard 4.0.3. <https://owasp.org/www-project-application-security-verification-standard/> (2021)
20. OWASP Foundation: OWASP top 10:2021 – the ten most critical web application security risks. <https://owasp.org/Top10/> (2021)
21. PostgreSQL Global Development Group: PostgreSQL 16 documentation: Row security policies. <https://www.postgresql.org/docs/16/ddl-rowsecurity.html> (2023)
22. Provos, N., Mazières, D.: A future-adaptable password scheme. In: Proceedings of the USENIX Annual Technical Conference, FREENIX Track. pp. 81–91. USENIX Association (1999)
23. Rahman, A., Williams, L.: Security practices in DevOps. In: Proceedings of the Symposium and Bootcamp on the Science of Security (HotSos '16). pp. 109–111. ACM (2016). <https://doi.org/10.1145/2898375.2898383>
24. Rose, S., Borchert, O., Mitchell, S., Connelly, S.: Zero trust architecture. Tech. Rep. NIST Special Publication 800-207, National Institute of Standards and Technology (2020). <https://doi.org/10.6028/NIST.SP.800-207>
25. Saltzer, J., Schroeder, M.: The protection of information in computer systems. Proceedings of the IEEE **63**(9), 1278–1308 (1975). <https://doi.org/10.1109/PROC.1975.9939>
26. Sandhu, R., Coyne, E., Feinstein, H., Youman, C.: Role-based access control models. Computer **29**(2), 38–47 (1996). <https://doi.org/10.1109/2.485845>